NOR1060 - Política de protección de datos personales

Proyecto	Autor
ISBE	finReg360

Fecha	Colaboradores
21.11.2025	Javier Ibañez GT Gobernanza

Financiado por la Unión Europea NextGenerationEU
Gobierno de España Ministerio para la Transformación Digital y de la Función Pública
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid
ALASTRIA

Índice

1. Introducción 3
1.1 Contexto del proyecto ISBE 3
1.2 Definiciones 4
2. Roles y responsabilidades en el tratamiento de datos personales en el entorno ISBE 6
3. Principios y obligaciones de cumplimiento en materia de protección de datos a aplicar por los responsables del tratamiento en el entorno ISBE 9
3.1 Principios del tratamiento 9
3.2 Terceros que acceden a datos 13
3.3 Ejercicio de derechos 14
3.4 Análisis de riesgos y evaluaciones de impacto 16
3.5 Controles técnicos y organizativos 16
3.6 Política de Privacidad por diseño y por defecto 17
3.7 Empleados 18
3.8 Gestión de incidentes de seguridad 18
3.9 Auditoría 19
4. Legislación aplicable 20
5. Revisión y actualización 21

1. Introducción

La presente Política tiene por objeto regular el régimen jurídico aplicable a la **protección y al tratamiento de datos personales** manejados o tratados dentro de la red blockchain gestionada por ISBE, una iniciativa estratégica impulsada por la Comunidad de Madrid y el Consorcio Red Alastria, garantizando un nivel homogéneo de cumplimiento para cualquier entidad participante que participe en los casos de uso de ISBE.

Resultan directamente aplicables a dicha protección como normas deónticas en el contexto de la Unión Europea tanto el Reglamento General de Protección de Datos (en adelante, "RGPD") como la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, "LOPDGDD").

La presente Política será de aplicación obligatoria para:

- **Entidades participantes:** Los tratamientos de datos personales que lleven a cabo las entidades participantes como "responsables del tratamiento" (en el sentido del RGPD) en el desenvolvimiento de los casos de uso desplegados sobre ISBE.

- **ISBE:** Los tratamientos de datos personales que ISBE realice:
  - Como operador de la infraestructura, en calidad de responsable del tratamiento para sus propias actividades (gobernanza, logs, gestión de nodos, etc.).
  - Como "encargado del tratamiento" (en el sentido del RGPD), cuando trate datos personales por cuenta de una entidad participante responsable del tratamiento en el contexto de un caso de uso concreto.

Su aceptación constituye requisito imprescindible para participar en la red blockchain y utilizar cualquiera de sus funcionalidades.

Cada entidad participante deberá incorporar estas directrices a su propio marco normativo interno, desarrollándolas y adaptándolas en políticas concretas (p. ej. políticas de privacidad, seguridad, conservación de datos, gestión de derechos), sin que pueda en ningún caso rebajarse el nivel de exigencia aquí previsto.

1.1 Contexto del proyecto ISBE

La Infraestructura de Servicios Blockchain de España (ISBE) es una iniciativa estratégica impulsada por la Comunidad de Madrid y el Consorcio Red Alastria, en el marco del Programa de Redes Territoriales de Especialización Tecnológica (RETECH), con financiación de los fondos Next Generation EU. Su objetivo es crear una red pública permisionada de confianza, orientada a proporcionar servicios digitales avanzados basados en tecnología blockchain/DLT, con plena validez jurídica y cumplimiento normativo europeo.

ISBE se configura como una infraestructura neutral, auditable y descentralizada, que actúa como soporte para:

- Registros electrónicos cualificados de datos (que componen evidencias procesales), atributos o credenciales verificables.
- Sistemas de identidad digital y de atributos y credenciales verificables alineados con el marco europeo del Reglamento eIDAS2 y en particular de la Cartera Europea de Identidad Digital (EUDI Wallet).
- Servicios de confianza interoperables con los estándares ETSI, W3C, OIDC/OAuth2 y CSC.

La red responde a la necesidad de dotar al ecosistema español de un entorno tecnológicamente robusto y jurídicamente conforme al ordenamiento, que garantice la integridad, autenticidad y trazabilidad de los datos registrados, promoviendo la transparencia, la eficiencia y la seguridad en las relaciones jurídicas y sus correspondientes procesos públicos y privados.

El proyecto involucra a un conjunto de actores clave (administraciones públicas, proveedores de servicios de confianza cualificados (QTSP), empresas tecnológicas, entidades académicas y auditores acreditados) que cooperan bajo un modelo de gobernanza distribuida y una estructura de cumplimiento común, alineada con las normas europeas y nacionales más recientes -entre otras, eIDAS2, RGPD, NIS2, DORA y el Esquema Nacional de Seguridad (ENS)-.

1.2 Definiciones

Las siguientes definiciones resultarán de aplicación a la presente Política.

- **Dato personal:** toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente.

- **Tratamiento:** cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción.

- **Infraestructura ISBE:** conjunto de componentes tecnológicos, organizativos y de gobernanza que conforman el entorno ISBE, incluyendo redes de registro distribuido y los elementos de su arquitectura-contratos inteligentes, mecanismos de validación y control y demás elementos que sirven de soporte a los casos de uso en las diferentes estratos o capas técnicas de aquella-.

- **Responsable del tratamiento:** la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros.

  Las entidades participantes pueden actuar como responsables del tratamiento respecto a los casos de uso en los que participen.

Por otra parte, ISBE también podrá actuar como responsable del tratamiento independiente como operador de la infraestructura, cuando no actúe por cuenta de las entidades participantes en la aplicación de los casos de uso.

- **Encargado del tratamiento:** la persona física o jurídica, autoridad pública, servicio u otro organismo que trate datos personales por cuenta del responsable del tratamiento.

  En el desarrollo de los casos de uso por cuenta de las entidades participantes, ISBE en principio actúa como encargado del tratamiento, esto es, la entidad que trata datos personales por cuenta del responsable del tratamiento, conforme al artículo 4.8 del RGPD. Su intervención se limita a las funciones expresamente documentadas e instruidas por el Responsable en cuyo interés o provecho actúa, garantizando la aplicación de medidas técnicas y organizativas adecuadas para la protección de los datos tratados.

- **Entidad participante:** organizaciones y entidades, públicas o privadas, que intervienen en el entorno ISBE con las funciones y competencias que se le atribuyen expresamente en la Memoria y Políticas de ISBE., sin perjuicio de la aplicación debida de esta Política a otras categorías de usuarios.

- **Caso de uso:** aplicaciones, procesos o servicios concretos desarrollados sobre la infraestructura ISBE, que pueden implicar la utilización de tecnologías de registro distribuido y, en su caso, el tratamiento de datos personales (ej. tokenización de activos, identidad digital, sellado de tiempo, notarización).

- **Seudonimización:** técnica de tratamiento donde los datos que no pueden atribuirse a un interesado sin utilizar información adicional, requieren que dicha información adicional figure por separado y, además, esté sujeta a medidas técnicas y organizativas destinadas a garantizar que los datos personales no se atribuyan a una persona física identificada o identificable (Artículo 4.5 RGPD).

- **Violación de la seguridad de los datos personales**: toda violación de la seguridad que ocasione la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos (4.12 RGPD).

- **Incumplimiento:** cualquier actuación contraria a las presentes directrices o a la normativa aplicable en materia de protección de datos y seguridad de la información.

2. Roles y responsabilidades en el tratamiento de datos personales en el entorno ISBE

El RGPD solo será de aplicación en la medida en que, en el contexto de los casos de uso desplegados sobre ISBE, se traten datos personales de personas físicas identificadas o identificables. Cuando los datos registrados en la infraestructura sean anónimos o no permitan, ni siquiera de forma indirecta, la identificación de una persona física no resultará de aplicación la normativa de protección de datos.

En todo caso, las entidades participantes deberán diseñar sus casos de uso de forma que, por defecto, se evite el registro en la cadena (*onchain*) de datos personales y se limite la información registrada en la red blockchain a identificadores de forma alfanumérica de longitud fija (*hasheados* y salteados y/o generados con clave) o bien otro tipo de referencias técnicas que no permitan la identificación directa de los interesados.

2.1 ISBE como responsable del tratamiento

ISBE actuará como responsable del tratamiento, en los términos del artículo 4.7 RGPD, respecto de los tratamientos de datos personales que realice para la gestión y operación de la infraestructura, incluyendo, entre otros:

- Gestión de la gobernanza técnica y de los datos de los órganos de decisión del ecosistema.
- Gestión de los nodos operados directamente por ISBE o por sus proveedores en su nombre.
- Registros de actividad, logs técnicos y trazabilidad de eventos necesarios para garantizar la seguridad, disponibilidad e integridad de la red.
- Gestión de accesos, credenciales técnicas y roles de administración.
- Gestión de datos de clientes y proveedores ISBE.
- Gestión de datos de empleados ISBE.

En estos casos, ISBE determinará de forma autónoma los fines y medios del tratamiento, aprobando su propio Registro de Actividades de Tratamiento, análisis de riesgos y, en su caso, evaluaciones de impacto.

2.2 ISBE como encargado del tratamiento

ISBE actuará como encargado del tratamiento, en los términos del artículo 4.8 y 28 RGPD, cuando trate datos personales por cuenta de una entidad participante responsable del tratamiento en el contexto de un caso de uso concreto desplegado sobre la infraestructura.

En estos supuestos:

- La entidad participante determinará los fines y medios esenciales del tratamiento.
- ISBE se limitará a ejecutar las instrucciones documentadas recibidas, proporcionando los servicios de infraestructura, operación técnica y soporte necesarios para el funcionamiento del caso de uso.
- La relación se articulará, a efectos de cumplir el régimen vigente de protección de datos personales, mediante el correspondiente contrato de encargo de tratamiento, de conformidad con los requisitos del art. 28 RGPD.

2.3 Entidades participantes como responsables o corresponsables del tratamiento

Cada entidad participante -o en su caso cualquier otra categoría de usuario de la red- será responsable del tratamiento respecto de los datos personales que trate en el marco de los casos de uso que promueva o en los que participe, en la medida en que determine los fines y los medios del tratamiento.

Cuando dos o más entidades participantes determinen conjuntamente los fines y medios de un tratamiento (por ejemplo, en casos de uso compartidos o interadministrativos), tendrán la consideración de corresponsables de tratamiento conforme al artículo 26 RGPD, debiendo suscribir el correspondiente acuerdo de corresponsabilidad que defina, de manera transparente, las respectivas responsabilidades de cada parte en el cumplimiento de las obligaciones derivadas del RGPD.

2.4 Operadores de nodos y otros participantes técnicos

Cuando los nodos de la red sean operados directamente por entidades participantes, el tratamiento de los datos replicados en dichos nodos se integrará en la condición de responsables o corresponsables de esas entidades, sin perjuicio de las obligaciones adicionales que se deriven de los acuerdos internos de gobernanza de ISBE.

Cuando los nodos sean operados por proveedores tecnológicos o terceros que actúen por cuenta de una entidad participante o de ISBE, estos terceros tendrán la condición de encargados del tratamiento y deberán suscribir el correspondiente contrato conforme al artículo 28 RGPD.

2.5 Proveedores externos

Los proveedores externos que presten servicios de soporte, desarrollo, auditoría, operación o mantenimiento y que, como consecuencia de ello, tengan acceso a datos personales tratados en el entorno ISBE, deberán ser calificados como encargados del tratamiento y estar sujetos a los requisitos del artículo 28 RGPD y a las políticas de selección y homologación de proveedores que, en su caso, resulten aplicables.

2.6 Usuarios finales

Los usuarios finales (personas físicas o representantes de entidades) que interactúen con casos de uso desplegados sobre ISBE tendrán, a efectos de esta Política, la condición de interesados o titulares de datos personales, con los derechos y garantías previstos en el RGPD y en la LOPDGDD.

3. Principios y obligaciones de cumplimiento en materia de protección de datos a aplicar por los responsables del tratamiento en el entorno ISBE

3.1 Principios del tratamiento

Cada responsable de tratamiento deberá adoptar políticas y procedimientos apropiados, así como implementar medidas técnicas y organizativas adecuadas y verificables, que permitan garantizar y evidenciar que los datos personales se procesan de acuerdo con la regulación aplicable, y en concreto con lo que dispone el RGPD en su artículo 5, el cual enumera así los principios de tratamiento de datos personales que debe aplicar cada responsable del tratamiento en todos y cada uno de sus tratamientos.

"Los datos personales serán:

a) tratados de manera lícita, leal y transparente en relación con el interesado («licitud, lealtad y transparencia»);

b) recogidos con fines determinados, explícitos y legítimos, y no serán tratados ulteriormente de manera incompatible con dichos fines; de acuerdo con el artículo 89, apartado 1, el tratamiento ulterior de los datos personales con fines de archivo en interés público, fines de investigación científica e histórica o fines estadísticos no se considerará incompatible con los fines iniciales («limitación de la finalidad»);

c) adecuados, pertinentes y limitados a lo necesario en relación con los fines para los que son tratados («minimización de datos»);

d) exactos y, si fuera necesario, actualizados; se adoptarán todas las medidas razonables para que se supriman o rectifiquen sin dilación los datos personales que sean inexactos con respecto a los fines para los que se tratan («exactitud»);

e) mantenidos de forma que se permita la identificación de los interesados durante no más tiempo del necesario para los fines del tratamiento de los datos personales; los datos personales podrán conservarse durante períodos más largos siempre que se traten exclusivamente con fines de archivo en interés público, fines de investigación científica o histórica o fines estadísticos, de conformidad con el artículo 89, apartado 1, sin perjuicio de la aplicación de las medidas técnicas y organizativas apropiadas que impone el presente Reglamento a fin de proteger los derechos y libertades del interesado («limitación del plazo de conservación»);

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su

pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»).

El responsable del tratamiento será responsable del cumplimiento de lo dispuesto en el apartado 1 y capaz de demostrarlo («responsabilidad proactiva»).”

Dentro del marco ISBE, estos principios se aplicarán en los casos de uso de la siguiente manera:

a) Licitud, lealtad y transparencia:

Con carácter previo al desarrollo de cualquier tratamiento de datos personales, se considerará su adecuación a las bases legitimadoras de los tratamientos recogidas en el artículo 6 RGPD, verificándose que se encuentren amparados en una o varias de las bases del tratamiento previstas por el artículo 6 RGPD. Dentro de las bases de legitimación previsiblemente más comunes, cabe destacar las siguientes:

(i) Consentimiento en el tratamiento

- Para cualquier operación de red, se deberá poner especial cuidado en que el consentimiento de los interesados se otorgue mediante un acto expreso que establezca una prueba de la voluntad libremente dada, específica, informada e inequívoca.

(ii) Gestión de la ejecución de un contrato o de un proceso de tratos preliminares previos a la celebración del contrato

- Cuando el responsable del tratamiento trate los datos personales para ejecutar un contrato o para implementar medidas precontractuales o relativas a los tratos preliminares a la celebración de un contrato, a petición del interesado.

(iii) Cumplimiento de una obligación legal

- Comunicación de los datos personales a las Administraciones Públicas cuando su cesión sea obligatoria por la legislación vigente, por razones de interés público.

(iv) Interés legítimo del responsable del tratamiento

- En este caso, con el fin de asegurar que se han tenido en cuenta las garantías necesarias y no perjudicar los derechos de los interesados en materia de protección de datos personales, previamente se deberán llevar a cabo los correspondientes análisis de ponderación entre los mencionados intereses legítimos y los derechos de los interesados, adoptándose las medidas precisas para asegurar que estos resulten adecuada y proporcionadamente protegidos s.

Por otro lado, antes de recopilar cualquier tipo de datos de carácter personal, el responsable del tratamiento informará a los interesados de una manera simple, clara y fácil de entender, sobre los diferentes aspectos relacionados con sus datos personales y los tratamientos.

Así, se incorpora en todos los medios y sistemas de recogida de datos personales un clausulado específico informativo de protección de datos que recoge todos los elementos relevantes para proteger la privacidad, de acuerdo con los artículos 13 RGPD y 11 LOPDGDD:

- La identidad y los datos de contacto del responsable del tratamiento y del Delegado de Protección de Datos (DPO), si se hubiese designado.
- Los fines del tratamiento a que se destinan los tratamientos de datos personales.
- La base jurídica del tratamiento de los datos.
- Los intereses legítimos del responsable del tratamiento o de un tercero si el tratamiento es necesario para satisfacer sus respectivos intereses legítimos
- Los destinatarios o las categorías de destinatarios de los datos personales.
- La intención de transferir datos personales a un tercer país u organización internacional y la referencia a las garantías adecuadas o apropiadas para realizar dichas transferencias.
- El plazo durante el cual se conservarán los datos personales, y el criterio utilizado para determinar dicho periodo.
- La existencia y referencia de los derechos de los interesados.
  Respecto a la supresión de los datos, se informará de que se garantizará mediante la anonimización o desvinculación total de los datos personales y, se eliminarán las bases de datos *offchain* que contengan información asociada al identificador del usuario, o los datos mismos, una vez transcurridos los plazos de conservación definidos por el responsable del tratamiento, o en su caso, bloquearse hasta su supresión definitiva, según proceda.
  En el caso del derecho de rectificación, se deberá informar que, cuando proceda, el responsable del tratamiento podrá registrar una transacción correctora posterior, que deje constancia de la modificación efectuada sin eliminar la transacción original, preservando la trazabilidad y la integridad propias de la tecnología blockchain.
- El derecho a presentar una reclamación ante una autoridad de control, y la vía oportuna y procedimiento a seguir para la presentación.
- Especificación relativa a si la comunicación de datos personales es un requisito legal o contractual necesario para suscribir un contrato. En este sentido, los datos así cedidos serán los estrictamente imprescindibles para la prestación del servicio, la cual deberá estar amparada en un contrato suscrito con el prestador del servicio o cuando exista un imperativo legal y/o contractual por razón de otro tipo de negocio jurídico.
- La existencia en su caso de decisiones automatizadas, como la “elaboración de perfiles” (4.4 RGPD) por dispositivos de inteligencia artificial (IA); la lógica aplicable en el caso de IA generativa, la importancia y consecuencias de este tratamiento para la parte interesada, sin perjuicio de las obligaciones que impone en el ámbito europeo el Reglamento (UE) 2024/1689, de 13 de junio, de Inteligencia Artificial (RIA), y en concreto la calificación del riesgo de vulneración de derechos fundamentales para el interesado como “alto” ex art. 9 RIA impuesta al fabricante del dispositivo, junto con las de implantar, documentar y mantener un sistema de gestión de riesgos relativo a sus dispositivos y sistemas de IA de alto riesgo

Asimismo, se deberá informar respecto al hecho de que los datos personales se tratarán necesaria y sistemáticamente fuera de la cadena de bloques (*offchain*), evitando el almacenamiento directo de información personal en la red blockchain y limitando el registro *onchain* únicamente a identificadores seudonimizados o hashes técnicos que no permitan la identificación de personas físicas.

Por otra parte, cuando los datos personales se obtienen a través de terceros, también se debe informar a los interesados en relación con el artículo 14 RGPD incorporando la tipología de datos tratados y el origen de los mismos.

b) Limitación de la finalidad.

Los datos personales solo podrán utilizarse únicamente para los fines previamente definidos y legítimos en cada caso de uso.

En sistemas inmutables, y en particular en las redes de tecnología de registro distribuido gestionadas por ISBE, deberán implementarse mecanismos que eviten la incorporación de información para finalidades distintas de las autorizadas.

La responsabilidad de cumplimiento recae en el responsable del tratamiento, que deberá definir, documentar e implantar los controles necesarios para garantizar la correcta aplicación de este principio. Cada entidad participante responderá de las consecuencias derivadas de deficiencias en dichos controles y mantendrá indemne a ISBE frente a cualquier reclamación, sanción o perjuicio ocasionado por incumplimientos imputables a su ámbito de actuación.

En todo caso, como parte esencial de este principio, se entenderá que el responsable del tratamiento se compromete a establecer filtros, controles técnicos y organizativos, así como procedimientos de validación y planificación preestablecida, que aseguren que los datos personales solo sean tratados para la finalidad legítima definida en cada caso de uso. Dichos controles deberán impedir su utilización para finalidades distintas, estar documentados y mantenerse actualizados en el marco del Registro de Actividades de Tratamiento (en adelante, RAT) de cada responsable del tratamiento.

c) Minimización de datos.

Los datos personales deben ser adecuados, relevantes y estar limitados a los fines para los que se tratan. Para ello, se deben adoptar medidas que garanticen que estos datos se puedan borrar o rectificar, en caso de ser innecesarios o inexactos, respectivamente.

En el entorno ISBE, este principio se traduce en la obligación de evitar la recogida o incorporación de información excesiva o no necesaria en los sistemas, especialmente en aquellos que tienen carácter inmutable propio de un sistema descentralizado y distribuido como la red ISBE, que emplea DLT / TRD. para registrar transacciones cripto-cifradas, En concreto, se evitará en toda transacción o bloque el almacenamiento directo de información personal en la red blockchain, limitando el registro en el libro mayor electrónico descentralizado (en la cadena u *onchain*) a la anotación y guarda de identificadores alfanuméricos anónimos o seudonimizados o hashes técnicos que no permitan la identificación de personas físicas.

La responsabilidad de cumplir con el presente principio corresponde al responsable del tratamiento, que deberá establecer mecanismos de diseño y control para garantizar que únicamente se traten los datos estrictamente necesarios en relación con la finalidad definida.

En todo caso, como parte esencial de este principio, se entenderá que el responsable del tratamiento se compromete a implantar filtros de entrada, limitaciones técnicas y organizativas, y procedimientos de validación previa, que impidan que se incorporen o traten más datos de los estrictamente necesarios.

Asimismo, el responsable del tratamiento deberá incluir en su política de privacidad un aviso expreso a los interesados advirtiendo que no deben introducir datos personales o información que permita la identificación directa o indirecta de personas físicas.

d) Exactitud.

Los datos personales tratados deberán ser exactos y estar actualizados, de forma que se evite el uso de información incorrecta u obsoleta que pueda generar efectos negativos sobre los interesados.

En el marco del entorno ISBE, este principio exige que el responsable del tratamiento establezca procedimientos de verificación y actualización periódica de los datos que se incorporen a los casos de uso, con especial foco en prevenir la inclusión de datos en los sistemas en los que no resulta posible rectificar la información una vez registrada. En todos los sistemas, la exactitud se deberá comprobar y exigir antes de la incorporación del dato personal, mediante controles previos de validación y limpieza de información.

En todo caso, como parte esencial de este principio, se entenderá que el responsable del tratamiento se compromete a implantar mecanismos de validación, revisión periódica y control de calidad de la información, que eviten la persistencia de datos inexactos en el entorno ISBE y garanticen que los tratamientos se basan siempre en información veraz y actualizada.

e) Limitación del plazo de conservación.

Los responsables del tratamiento deberán:

- Gestionar los plazos de conservación en sistemas offchain, donde los datos personales se almacenen de forma controlada y puedan ser suprimidos o anonimizados al cumplirse el plazo definido.
- Asegurar que en los sistemas inmutables, especialmente el libro mayor electrónico, donde no puede limitarse el tiempo de conservación, únicamente se incorporen referencias técnicas, identificadores seudonimizados o hashes no reversibles, sin que por sí mismos constituyan datos personales.

En todo caso, como parte esencial de este principio, los responsables del tratamiento se comprometen a establecer políticas de conservación y supresión documentadas, así como controles que garanticen que los datos personales no se mantendrán más allá de lo necesario, y que cualquier referencia en entornos inmutables carezca de valor identificativo por sí misma.

f) Integridad y confidencialidad.

Los datos personales deberán ser tratados de manera que se garantice su seguridad, integridad y confidencialidad, aplicando medidas técnicas y organizativas apropiadas que eviten su acceso, alteración, pérdida o divulgación no autorizada, de conformidad con el artículo 5.1.f y 32 del RGPD.

Para todos los responsables del tratamiento, este principio requiere que los casos de uso se diseñen bajo un esquema de seguridad por defecto, incorporando desde el inicio controles que preserven la integridad de los datos y restrinjan su acceso únicamente a las partes autorizadas.

3.2 Terceros que acceden a datos

Las entidades participantes en el entorno ISBE pueden tener acuerdos de prestación de servicios de distinta índole con proveedores externos, los cuales podrían tener acceso a datos personales y realizar cualquier tipo de tratamiento sobre ellos.

Por ello, cada responsable del tratamiento tiene la obligación, de conformidad con el artículo 28 del RGPD a suscribir un contrato de encargado de tratamiento con cada uno de los proveedores con acceso

a datos donde se establezcan las obligaciones y medidas que deberá adoptar el encargado para poder tratar los datos personales responsabilidad del responsable del tratamiento que afecten al entorno ISBE. En ese sentido, cada responsable debe verificar que los terceros cumplen con las obligaciones del art. 28 RGPD que se enumeran a continuación y que deberán recogerse en el precitado contrato de encargado:

- Tratar los datos personales únicamente siguiendo instrucciones documentadas del responsable del tratamiento.
- Garantizar que las personas autorizadas para tratar datos personales se hayan comprometido a respetar la confidencialidad o estén sujetas a una obligación de confidencialidad de naturaleza estatutaria o contractual.
- Tomar todas las medidas de seguridad necesarias de conformidad con el art. 32 RGPD.
- No recurrir a otro encargado del tratamiento sin la autorización previa por escrito, específica o general, del responsable del tratamiento. En caso de recurrir a otro encargado del tratamiento, deberá imponer a este las mismas obligaciones de protección de datos que las estipuladas en el contrato entre el responsable del tratamiento y el encargado del tratamiento.
- Asistir al responsable, teniendo cuenta la naturaleza del tratamiento, a través de medidas técnicas y organizativas apropiadas, siempre que sea posible, para que este pueda cumplir con su obligación de responder a las solicitudes que tengan por objeto el ejercicio de los derechos de los interesados.
- Asistir igualmente con las medidas apropiadas al responsable a garantizar el cumplimiento de las obligaciones establecidas en los artículos 32 a 36, teniendo en cuenta la naturaleza del tratamiento y la información a disposición del encargado.
- A elección del responsable, suprimir o devolver todos los datos personales una vez finalice la prestación de los servicios de tratamiento.
- Poner a disposición del responsable toda la información necesaria para demostrar el cumplimiento de las obligaciones establecidas en el presente artículo, así como para permitir y contribuir a la realización de auditorías, incluidas inspecciones, por parte del responsable o de otro auditor autorizado por dicho responsable.

Por otra parte, en cada contrato de encargo de tratamiento deberá establecerse el objeto, la duración, la naturaleza y la finalidad del tratamiento, así como el tipo de datos personales y categorías de interesados que el encargado tratará por cuenta del responsable del tratamiento.

A los efectos de cumplir la normativa aplicable en materia de protección de datos y garantizar la contratación diligente de los encargados del tratamiento, ISBE implementa una Política de Externalización por la que, se verifica la adecuada regulación del encargo del tratamiento de conformidad con el art. 28 RGPD, se clasifica a los proveedores según el riesgo y el acceso o no a datos personales, y se requieren evidencias de cumplimiento a os encargados.

3.3 Ejercicio de derechos

Cada responsable del tratamiento debe garantizar que los interesados, puedan ejercer los siguientes derechos reconocidos por el RGPD sobre sus datos personales con todas las garantías que la norma ofrece.

En el contexto del entorno ISBE, en particular, que los datos personales de las personas físicas (por ejemplo, inversores o usuarios identificables) no se almacenan en la cadena de bloques.

La información identificativa se conserva exclusivamente en los sistemas *offchain* (así, en la plataforma o *backend* del Marketplace), donde se registran y gestionan, permitiendo atender de forma ágil y completa los derechos de los interesados.

.

El identificador vinculado a claves públicas o direcciones de la red se considera un dato seudonimizado mientras exista un nexo con la información *offchain*; sin embargo, deja de ser un dato personal si se elimina dicho vínculo.

Por tanto, para poder atender adecuadamente los ejercicios de derechos en materia de protección de datos, se deberá:

- Evitar el almacenamiento directo de información personal en la red blockchain, limitando el registro *onchain* a identificadores seudonimizados o hashes técnicos que no permitan la identificación de personas físicas.

- Garantizar el derecho de supresión mediante la anonimización o desvinculación total de los datos personales. Cuando proceda, deberán eliminarse las bases de datos *offchain* que contengan información asociada al identificador del usuario, una vez transcurridos los plazos de conservación definidos por el responsable del tratamiento, o en su caso, bloquearse los datos, impidiendo su acceso a ellos o a las bases hasta su supresión definitiva, según proceda.

- Asegurar que los datos guardados *onchain* no permitan la identificación directa y que los datos complementarios almacenados *offchain* que sí la permitan puedan ser a su debido tiempo efectivamente suprimidos o bloqueados, de modo que la información contenida en la cadena deje de considerarse dato personal.

- Aplicar, en caso de ejercicio del derecho de supresión de datos, un procedimiento de anonimización efectiva, eliminando la correspondencia entre el identificador único y la identidad del usuario (lista de direcciones, claves públicas o privadas asociadas). A partir de ese momento, las transacciones almacenadas en la cadena de bloques no podrán vincularse con ninguna persona física, garantizando así el derecho de supresión.

- Respecto al derecho de rectificación, cuando proceda, el responsable del tratamiento podrá registrar una transacción correctora posterior, que deje constancia de la modificación efectuada sin eliminar la transacción original, preservando la trazabilidad y la integridad propias de la tecnología blockchain.

Estas medidas permiten que, aun en un entorno tecnológico que por su diseño dificulta la modificación o eliminación de registros, los derechos de los interesados puedan ejercerse de manera efectiva y verificable, garantizando la compatibilidad de la tecnología blockchain con los principios de protección de datos y con el marco jurídico del RGPD.

3.4 Análisis de riesgos y evaluaciones de impacto

Uno de los requerimientos que establece el RGPD tanto para responsables como encargados del tratamiento que realizan o desean realizar actividades de tratamiento con datos personales y que, por tanto, se deberá cumplir en el entorno ISBE por las entidades participantes, es llevar a cabo un análisis de riesgos de la seguridad de la información, con el fin de determinar y establecer las medidas de seguridad y control precisas para cumplir los principios de protección desde el diseño y por defecto.. Para evaluar un riesgo es necesario tener en cuenta todos los posibles escenarios y la probabilidad de que las amenazadas se materialicen.

Este análisis de riesgos debe incluir los siguientes elementos:

- Una descripción sistemática de la actividad de tratamiento.
- Una evaluación de la necesidad y proporcionalidad del tratamiento en relación con su finalidad
- Una medición y evaluación de los riesgos inherentes.
- La descripción de las medidas previstas para afrontar los riesgos, incluidas las de ciberseguridad y mecanismos complementarios que garanticen la protección de datos personales.

Asimismo, en relación con los tratamientos que por sus características son susceptibles de suponer un mayor riesgo en materia de protección de datos, el RGPD introduce el concepto de evaluación de impacto en protección de datos (EIPD o DPIA, en inglés) como una nueva herramienta de análisis de riesgos destinada a salvaguardar a los interesados del riesgo e impacto de determinadas amenazas sobre la privacidad de sus datos personales.

Un PIA (*Privacy Impact Assesment*) es, básicamente, un ejercicio de análisis de los riesgos que un determinado sistema de información, producto o servicio puede entrañar para la preservación de la privacidad e intimidad de las personas cuyos datos se tratan y, como consecuencia de ese análisis, de la gestión de dichos riesgos mediante la adopción de las medidas necesarias para eliminar o mitigar en lo posible aquellos que se hayan identificado.

Teniendo en cuenta la infraestructura ISBE, será necesario llevar a cabo una PIA antes de cada caso de uso que implique un tratamiento de datos personales.

3.5 Controles técnicos y organizativos

La seguridad se configura en el RGPD tanto como principio, según establece su artículo 5, de cuya aplicación se sigue la imposición de un deber general asociado al cumplimiento de las obligaciones que se desarrollan en los artículos 32 a 34.

En este contexto normativo, los datos personales deben tratarse de un modo que garantice su confidencialidad, disponibilidad e integridad, en interés de sus titulares. El art. 32 del RGPD, referido a la “seguridad del tratamiento”, enumera medidas técnicas y organizativas que deben implementarse como mínimo. Según el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como los riesgos de probabilidad y gravedad para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán las medidas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, -así, la seudonimización o el cifrado de datos personales-, previniendo con su adopción el eventual tratamiento no autorizado o ilícito y la pérdida, destrucción o daño accidental de los datos.

3.6 Política de Privacidad por diseño y por defecto

En el diseño de nuevos casos de uso en el entorno ISBE se deberá tener en cuenta desde un primer momento la privacidad de los titulares cuyos datos va a tratar, revisando de forma previa si el nuevo medio o finalidad de tratamiento respeta de forma clara todos los principios del art.5 RPGD, además de realizarse de forma segura.

Las decisiones sobre el diseño del sistema de tratamiento, su adquisición y su funcionamiento, deberán tener en cuenta los siguientes aspectos generales:

- **Minimización de los datos:** los sistemas de tratamiento de datos deberán diseñarse y seleccionarse de acuerdo con el objetivo de no recoger, tratar ni utilizar ningún tipo de dato personal, o de hacerlo con el menor número de datos personales posible.

- **Controlabilidad o capacidad de control:** un sistema de tecnología de la información deberá dotar a los interesados de medios de control eficaces relativos a sus datos personales. Las posibilidades relativas al consentimiento y a la oposición deben estar respaldadas por medios tecnológicos adecuados.

- **Transparencia:** tanto los desarrolladores como los operadores de sistemas de tecnología de la información deben cerciorarse de que los interesados estén suficientemente informados acerca de los medios de manejo de los sistemas. Deberán habilitarse el acceso y la información por medios electrónicos.

- **Usabilidad o facilidad de uso de los sistemas:** las funciones y los mecanismos relativos a la privacidad deben ser fáciles de utilizar, es decir, deben proporcionar la ayuda suficiente e interfaces simples que puedan ser utilizados también por usuarios con menor experiencia.

- **Confidencialidad de los datos:** es necesario diseñar y asegurar los sistemas de tecnología de la información de modo que solamente las personas autorizadas tengan acceso a los datos personales.

- **Calidad de los datos:** los responsables del tratamiento de datos deberán respaldar la calidad de los datos por medios técnicos adecuados, debiendo entenderse la noción de calidad de conformidad con lo previsto en los artículos 4.1, 5.1 y 13.5.g) del Reglamento (UE) 2023/2854, de 13 de diciembre de 2023, sobre normas armonizadas para un acceso justo a los datos y su utilización (Reglamento de Datos). Los datos pertinentes deberán ser accesibles en caso de que resulte necesario con fines legales, en un contexto de red pública y permisionada de pleno cumplimiento normativo como ISBE.

- **Limitación del uso:** Los sistemas de tecnología de la información que puedan utilizarse con distintos fines o que se manejen en un entorno multiusuario (es decir, sistemas conectados virtualmente, como almacenes de datos, almacenamiento en la nube o identificadores digitales) deberán garantizar que los datos y los procesos que sirvan para distintas tareas o fines puedan separarse entre sí de forma segura".

3.7 Empleados

El acceso a datos personales por parte de los empleados de cada responsable del tratamiento requiere que éstos sean profesionalmente cuidadosos y diligentes con su tratamiento y sigan una serie de directrices y estándares internacionales en materia de seguridad y confidencialidad que mitiguen el riesgo operativo u operacional, Cada responsable del tratamiento firmará cláusulas de confidencialidad con sus empleados, así como realizará acciones de concienciación y formación dirigidas a sus empleados a fin de que cuenten con medios e información apropiados para el correcto tratamiento de los datos que han de manejar en el ejercicio de su cargo.

Asimismo, se deberá contar con un procedimiento sobre las funciones y obligaciones del personal en materia de seguridad, protección de datos y uso de las herramientas informáticas a través del cual se den a conocer todas estas obligaciones a todos los empleados desde sus primeros días en la compañía y cuyo cumplimiento se recuerde periódicamente, debiendo mantenerse siempre en un lugar accesible para su consulta en caso de ser necesario.

3.8 Gestión de incidentes de seguridad

Cada responsable del tratamiento debe estar preparado para afrontar la gestión de un incidente de seguridad, de forma que pueda responder ágil y eficazmente ante cualquier brecha a los efectos de /minimizar los posibles impactos del incidente en la propia compañía y en los terceros que pudieran verse afectados.

En función de la magnitud del daño es necesario notificar las brechas de seguridad a la Agencia Española de Protección de Datos en un plazo de 72 horas desde su detección cuando se trate de una afectación grave para los interesados, y además, a los afectados, en los casos muy graves.

Cada responsable del tratamiento deberá contar con un procedimiento adecuado para la Gestión de Brechas de Seguridad y eventual notificación a la Autoridad de Control o a los propios afectados.

Por otra parte, cuando un incidente o incumplimiento afecte directa o indirectamente a la tecnología, a los componentes técnicos o a los servicios provistos por ISBE, el responsable del tratamiento deberá informar a ISBE sin dilación indebida, a fin de permitir la evaluación técnica, la mitigación del impacto y la preservación de la integridad del entorno.

A efectos del presente marco, entre otros, se consideran incidentes:

- Cualquier acceso, alteración, pérdida, destrucción, cifrado o divulgación no autorizada de datos personales.
- Fallos de seguridad que comprometan la infraestructura blockchain o los sistemas interconectados.
- Vulnerabilidades detectadas en contratos inteligentes, nodos o mecanismos de validación.
- Uso indebido, negligente o no autorizado de credenciales, claves criptográficas o configuraciones de red. Cualquier incumplimiento material de las obligaciones de seguridad o confidencialidad derivadas del RGPD, la LOPDGDD o del contrato de encargo de tratamiento.

El responsable del tratamiento deberá informar a ISBE de forma inmediata y sin dilación indebida a dataprotection@alastria.io.

3.9 Auditoría

Cada responsable del tratamiento, de acuerdo con el artículo 32.1.d RGPD no sólo deberá aplicar medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, sino que además deberá realizar tareas de seguimiento, supervisión y auditoría de cumplimiento y aplicación de tales medidas. En este sentido, deberá contar con un plan de controles de protección de datos personales que contemple no solo la revisión de la efectividad de las medidas presentes, sino, además, la adopción de nuevas medidas idóneas para garantizar el cumplimiento de la normativa aplicable y el respeto de los derechos de los interesados.

4. Legislación aplicable

La presente Política se interpretará conforme a la legislación europea y nacional vigente en cada momento en materia de protección de datos personales (GDPR, LOPDGDD) y legislación conexa (Data Act, RIA, entre otras).

Para la resolución de cualquier conflicto, las Partes se someten expresamente a los juzgados y tribunales competentes de la ciudad de Madrid, renunciando así las Partes a cualquier otro fuero que pudiera corresponderles.

5. Revisión y actualización

La presente Política resultará de aplicación obligatoria para todos aquellos que formen parte del ecosistema de ISBE, así como para todos aquellos respecto de los cuales se establezca una relación contractual.

La presente Política será revisada por Comité de Cumplimiento y Regulación periódicamente, o cuando se produzcan cambios relevantes en la legislación aplicable, en el modelo operativo o en el entorno tecnológico.